



DATA PROTECTION POLICY

NOVEMBER 1, 2025

Harare Institute of Technology

Data Protection Policy

1. Purpose

The purpose of this policy is to establish a framework for Harare Institute of Technology (HIT) to ensure compliance with the Cyber and Data Protection Act (CDPA) [Chapter 12:07] and the Cyber and Data Protection Regulations, 2024 (S.I. 155 of 2024). This policy governs the lawful and secure processing of personal information belonging to Data Subjects, including students, staff, alumni, research participants, suppliers, and all other individuals connected with the Institute.

2. Scope

This policy applies to all HIT systems, processes, research, teaching, administrative, and commercial activities that involve the processing of personal data. It covers all processing of personal data in both electronic and physical (paper-based) formats. It is binding on all members of Harare Institute of Technology, including:

- 2.1 All academic, administrative, and support staff (full-time, part-time, and contract)
- 2.2 All students (Undergraduate, postgraduate, full-time, part-time, and distance learners)
- 2.3 All contractors, suppliers, and third-party service providers who process personal data on HIT's behalf.

3. Legal Framework

- 3.1 HIT acknowledges and affirms that the Cyber and Data Protection Act [Chapter 11:22], 2021, is the paramount legal framework governing the processing of personal data within Zimbabwe.
- 3.2 HIT shall comply with the registration and licensing requirements outlined in the Cyber and Data Protection Regulations, 2024 (S.I. 155 of 2024), including applying for and obtaining a Data Controller License commensurate with the organisation's processing tier. Payment of all requisite licensing fees. Ensuring the license is renewed annually before its expiry date.
- 3.3 HIT shall appoint a duly certified Data Protection Officer (DPO) as required by law. The Authority shall be formally notified of this appointment using Form DP2, in line with Section 12 of S.I. 155 of 2024.
- 3.4 HIT shall formally notify the Authority of the resignation or dismissal of the Data Protection Officer within fourteen (14) days of the termination of the DPO's contract.
- 3.5 HIT is committed to taking all reasonable and necessary steps to ensure comprehensive compliance with this policy. Breaches of this policy by staff shall result in disciplinary action, up to and including termination of employment, in accordance with HIT's internal disciplinary procedures.

4. Definition of key terms

For this policy, the following terms are defined as follows:

4.1 Data Controllers: The natural or legal person who determines the purpose and means of the processing of personal data. For this policy, HIT is the Data Controller.

4.2 Data Subject: An identifiable natural person.

4.3 Personal Data: This includes, but is not limited to, any information relating to a data subject. Identification numbers, student registration numbers, email addresses, physical addresses, phone numbers, financial information, academic records, health information, and images.

4.4 Processing: Any operation or set of operations performed upon personal data, manually or by automatic means, such as collection, recording, organisation, structuring, storage, adaptation, alteration, retrieval, consultation, use, disclosure by transmission, dissemination, alignment, combination, restriction, erasure, or destruction.

4.5 Sensitive Personal Data (Special Category Data): As defined in the Act, this includes data concerning a data subject's religious or philosophical beliefs, racial or ethnic origin, political opinions, sexual life, health, or biometric data.

4.6 Data Protection Officer (DPO): The person appointed by HIT as required by the Act to oversee data protection strategy and implementation.

4.7 Data Processor: Is a natural or legal person, public authority, agency, or other body that processes personal data on behalf of the Data Controller.

4.8 Record of Processing Activities (ROPA): A document that lists and explains all the ways an organisation collects, uses, stores, shares, and deletes personal data.

4.9 Data Protection Impact Assessment (DPIA): Is a risk assessment conducted before processing personal data that may present a high risk to individuals' rights and freedoms

4.10 Authority: Body responsible for enforcing data protection laws, supervising compliance, and receiving notifications such as ROPAs or DPIAs, in this case, the Post and Telecommunications Regulatory Authority of Zimbabwe (POTRAZ).

5. Data Protection Principles

HIT shall ensure that all personal data is processed in accordance with the following principles as mandated by the Act:

5.1 Processed lawfully, fairly, and in a transparent manner (CDPA, Section 13: subsection (b): Data shall be processed only with a lawful basis (consent,

contractual necessity or legal obligation) and in a manner that is clear and honest to the Data Subject.

- 5.2 **Collected for explicit, specified, and legitimate purposes and not further processed in a manner incompatible with those purposes (CDPA, Section 13: subsection (c)):** Personal data shall be collected and processed only for the specified purpose, not for any other additional purposes not originally specified without consent from the data subject.
- 5.3 **Adequate, relevant, limited to what is necessary in relation to the purposes for which it is processed (CDPA, Section 13: subsection (d)):** Only the minimum amount of personal information necessary to achieve the stated purpose shall be collected and processed.
- 5.4 **Accurate and, where necessary, kept up to date, with every reasonable step being taken to ensure that any inaccurate personal data is erased or rectified without delay (CDPA, Section 13: subsection (f)):** Reasonable steps will be taken to ensure that personal data is accurate and up to date.
- 5.5 **Retained in a form that allows for the identification of data subjects, for no longer than necessary with a view to the purposes for which the data is collected or further processed (CDPA, Section 7: subsection (c)):** Personal information shall be retained only for as long as required for the original purpose or as mandated by law. Retention periods must be clearly defined and documented.
- 5.6 **In order to safeguard the security, integrity, and confidentiality of the data, the controller or his representative, if any, shall take appropriate technical and organisational measures that are necessary to protect data: (CDPA, Section 18: subsection (1)):** Appropriate technical and organisational measures must be implemented to protect personal information.
- 5.7 **The data controller shall take all the necessary measures to comply with the principles and obligations set out in this Act (CDPA, Section 24: subsection (a)):** HIT, as the Data Controller, is responsible for, and must be able to demonstrate, compliance with all data protection principles.

6. Roles and Responsibilities

HIT, as the Data Controller, has the ultimate responsibility for ensuring compliance with the following legal obligations:

- 6.1.1 obtaining and maintaining the required **Data Controller Licence** from the authority (POTRAZ) as mandated by S.I. 155 of 2024.
- 6.1.2 appointing a qualified and certified **Data Protection Officer (DPO)**.
- 6.1.3 implementing and enforcing this policy and all related procedures.
- 6.1.4 ensuring Data Protection in all new systems and processes.
- 6.1.5 ensuring the continuous professional development of its certified Data Protection Officer (DPO), specifically by mandating their attendance at workshops and conferences hosted by the Authority.
- 6.1.6 ensuring transparency in the processing of personal data, as mandated by the Act.

6.2 Data Protection Officer (DPO)

- 6.2.1 Acts as the point of contact with the Authority and Data Subjects.
- 6.2.2 Monitoring compliance with the Act and S.I 155 of 2024, and internal data protection policies.
- 6.2.3 Advising on Data Protection Impact Assessments (DPIAs) and data processing activities.
- 6.2.4 Acting as a liaison between the Institute and the Authority.
- 6.2.5 Training and awareness creation for staff and other Data Processors.
- 6.2.7 Monitor compliance and advise the Controller and Data Processors on their Record of Processing Activities (ROPA) obligations and ensure that it exists and is up to date.

6.3 Staff and Students

Every individual handling personal information must:

- 6.3.1 Adhere to this policy and related procedures.
- 6.3.2 Complete mandatory data protection training.
- 6.3.3 Report any suspected or actual data breaches immediately to their supervisor and the DPO.

7. Lawful Basis for Processing Data

HIT shall only process personal data where at least one of the following lawful basis applies:

- 7.1 The data subject has given clear, specific, and unambiguous consent or
- 7.2 Processing is necessary for the performance of a contract with the data subjects
- 7.3 Processing is necessary for compliance with legal obligations.
- 7.4 Processing is necessary to protect the vital interests of the data subject or another natural person.
- 7.5 Processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in HIT.
- 7.6 Processing is necessary for the legitimate interests pursued by HIT or a third party, except where the interests of fundamental rights and freedoms of the data subjects override such interests.
- 7.7 For sensitive personal data, HIT shall rely on one of the specific conditions as outlined

in the Act, such as explicit consent, necessity for employment, law obligations, or protection of the data subject's vital interests.

8. Data Subject Rights

In accordance with the Act, HIT recognises and facilitates the following rights of data subjects:

- 8.1 **Right to be informed:** HIT shall inform data subjects of all required information when collecting their personal data, in line with CDPA Sections 15 and 16.
 - 8.2 **Right to Give and Withdraw Consent:** The right to give and withdraw consent voluntarily and explicitly without coercion or undue pressure.
 - 8.3 **Right to Access:** Request and obtain confirmation of whether their personal Information is being processed, and access to that data
 - 8.4 **Right to Rectification:** The right to have inaccurate or incomplete personal data corrected.
 - 8.5 **Right to Deletion (Right to be Forgotten):** The right to have their personal data erased in circumstances permitted by law, such as if the data is no longer needed for the purpose, if consent is withdrawn, if processing was unlawful, or if the data is false or misleading.
 - 8.6 **Right to Object to Processing:** The right to object to the processing of their personal Data in certain situations, including profiling or direct marketing.
 - 8.7 **Rights Related to Automated Processing:** Data subjects have the right not to be subjected to decisions based solely on automated processing that produce legal effects or similarly significant consequences for them
 - 8.8 **Right to Complain:** The right to report any breaches or infringements of their data rights to the DPO in the first instance, and also have the right to escalate complaints to the Authority if unsatisfied.
9. All requests to exercise these rights must be submitted in writing to the DPO. HIT shall respond to such requests within the timeline stipulated by the Act (21 days, extendable by notice).

10. Data protection by Design and Default

10.1 HIT shall integrate data protection into the design of its systems and processes and ensure that, by default, only necessary personal data is processed.

10.2 All systems or projects that involve personal data must complete a Data Protection Impact Assessment (DPIA) before processing begins.

11. Data Security

11.1 Technical Security Measures

HIT shall implement appropriate technical and organisational measures to protect personal data against unauthorised access, alteration, disclosure, or destruction. These measures include, but are not limited to:

11.1.1 Access controls (passwords, two-factor authentication)

11.1.2 Logging, monitoring and periodic vulnerability assessments and penetration tests

11.1.3 Encryption for sensitive data both in transit and at rest

11.1.4 Regular security audits and risk assessments.

11.1.5 Physical security controls for paper records and IT infrastructure

11.1.6 Secure disposal and shredding policies for physical records: secure wiping for electronic media

11.1.7 Endpoint security (antivirus, patch management), secure backups, and disaster recovery plans.

11.1.8 Contracts and audits for third-party processors to ensure equivalent protections, the Director of Information Communication Technology will maintain an inventory of systems processing personal data.

11.2.2 Organisational Security Measures

11.2.1 Staff training on data protection

11.2.2 Confidentiality agreements

11.2.3 Clear desk policies, and

11.2.4 Restricted access to physical records based on role necessity.

12. Data Breach Notification

In the event of a personal information security breach:

- 12.1 The breach must be reported immediately to the DPO
- 12.2 The DPO must notify the Authority (POTRAZ) within at least 24 hours of becoming aware of the breach.
- 12.3 If the breach is likely to result in a high risk to the rights and freedoms of individuals, the affected Data Subjects must be informed within at least 72 hours.
- 12.4 The breach and any remedial action must be documented.

13. International Data Transfer

HIT shall assess the adequacy of the recipient country's data protection or put in place appropriate safeguards (such as contracts) as required by law before any transfer. Personal information may only be transferred outside of Zimbabwe if an adequate level of protection is ensured in the recipient country, or if specific conditions are met, such as:

- 13.1 The Data Subject had given their written consent to the transfer.
- 13.2 The transfer is necessary for the performance of a contract between the Data Subject and HIT.
- 13.3 The transfer is necessary for compelling legitimate interests of HIT that are not overridden by the Data Subject's rights.

Notification: The Data Controller must notify the Authority of any intention to transfer or share data outside Zimbabwe.

14. Training and Awareness

- 14.1 HIT shall provide regular training and awareness programmes for staff on data protection obligations, secure handling of data, and breach reporting.

15. Penalties for Non-Compliance

Failure to comply with this policy and the relevant Zimbabwe legislation may result in:

- 15.1 Internal Disciplinary Action, up to and including dismissal, for staff and termination of contracts for third parties.
- 15.2 Legal sanctions and fines imposed by the Authority (POTRAZ), which can include

finest up to Level 11 or imprisonment for regulatory violations, and even higher penalties for grave offences under the CDPA, as specified in S.I.155 of 2024.

This policy is the authoritative document governing data protection at Harare Institute of Technology and must be adhered to by all stakeholders.

16 Policy Review

Unless circumstances dictate otherwise, the policy shall be reviewed within the five-year University Review Cycle.

Adoption Procedures

Accountable Officer	Vice Chancellor
Policy Administrator	Data Protection Officer
Oversight Role	Senate
Policy No.	To be assigned
Relevant Legislation	Cyber and Data Protection Act [Chapter 12:07] of 2021 Cyber and Data Protection Regulations (S.I. 155 of 2024)
Related Policies	ICTS Policy, Communications Policy
Approved Date	
Effective Date	
Review Date	Every five years
Senate Chair Signature	
Date	